

TABLETOP INCIDENT RESPONSE SCENARIO

“What If HVMC Got Hit by JOMANGY?” — Simulated Compromise, Detection & Response

Extends Cyber Threats & Vulnerabilities Criterion 1 and the Network Security “Monitor and Respond to Network Security Events” criterion — Horizon Valley Medical Center IAM Home Lab

Prepared by	dae Tech Resource 2 — Sabitha, IAM Home Lab (HVMC scenario)
Basis	Real detection/threat-intel findings from the JOMANGY malware diagnosis report (sample 679515b3...e39c00), replayed as a hypothetical incident against the HVMC lab network
Lab environment	IAMLab-Net 192.168.50.0/24 — UTM virtual network, Samba4 AD DC (hvmc.local)
Report date	September 2, 2026

1. Purpose & Scope

This document is a tabletop exercise, not a record of an actual security incident. It takes the real detection findings from the JOMANGY malware analysis already completed for this project (VirusTotal sample 679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00) and asks: if this malware family compromised the HVMC lab environment, how would it get in, how would it move, how would the lab's existing tools detect it, and how would it be resolved? The goal is to exercise incident-response thinking against the specific architecture already built for this 12-week project, rather than a generic playbook.

Stated assumption — read this first

The real JOMANGY campaign targets internet-facing FreePBX/Asterisk PBX systems. HVMC's current lab build (per the Network Security rubric answers) has no PBX/VoIP host, and IAMLab-Net is an outbound-only, NAT-style network with no inbound route from the internet — so the real-world mass-scanning entry vector does not directly apply as built. To run this scenario meaningfully, two assumptions are made and called out throughout: (1) a hypothetical VoIP host, HVMC-PBX01 (192.168.50.40), has been added to IAMLab-Net to serve department phone lines — a realistic addition for a medical center but not part of the current lab; and (2) the attacker's foothold comes from a phishing email (the same technique behind this project's Sep 4 SET deliverable) rather than a direct internet-facing exploit, since the lab network has no exposed inbound surface. Every step below is framed as “would happen” / “could happen,” not as something that occurred.

2. Environment Reference

Host	IP	Role in this scenario
HVMC-DC01	192.168.50.10	Samba4 AD Domain Controller / DNS — highest-value asset; must never be directly exposed to the compromised segment.
HVMC-CL01	192.168.50.20	Domain-joined client — the assumed phishing entry point (Reception workstation).
HVMC-PBX01 (hypothetical, for this exercise)	192.168.50.40	FreePBX/Asterisk VoIP PBX — not part of the current lab build; added here only to run the JOMANGY scenario. Serves Reception/Doctors/Nursing/Pharmacy phone lines.
HVMC-KALI	192.168.50.30	Analysis / IDS-IPS / SET host — used here as the defender's response workstation.
Gateway	192.168.50.1	UTM virtual network gateway (Shared Network, NAT-style, outbound-only).

IAMLab-Net is a single-segment, star-topology LAN with no internal VLAN or firewall boundary between hosts (per the Network Security rubric answer). That single fact is the crux of this scenario's risk: once any one host on the segment is compromised, nothing in the current architecture stops an attacker from reaching HVMC-DC01.

3. How the Malware Works

This section explains the mechanics of the JOMANGY family itself — what the sample does, step by step — independent of how it might reach HVMC. It is drawn from VirusTotal's automated code analysis of the sample plus the published JOMANGY/INJ3CTOR3 threat research already cited in the Criterion 1 malware-diagnosis report; no portion of the sample was executed to produce this description.

3.1 What it is

The analyzed file (679515b3...e39c00.sh) is a 48.90 KB Bash shell script — the Stage 1 dropper in a three-stage attack chain. It is not the final payload; its entire job is to prepare a Linux/FreePBX host for long-term, hard-to-remove attacker access, then hand off to later PHP-based components.

3.2 The three-stage chain

- Stage 1 — Bash dropper (this sample): runs first, with root or root-equivalent access already obtained through the entry exploit. It removes competing malware, creates backdoor accounts, installs the persistence mechanisms described below, and scrubs logs to hide its own tracks.
- Stage 2 — JOMANGY web shell (k.php and related files): a PHP backdoor Stage 1 downloads and writes into legitimate FreePBX web-application directories, giving the attacker a browser- or curl-reachable command interface that survives even if the original Bash dropper is deleted.
- Stage 3 — ZenharR web shell (wr.php / wor.php): a second, redundant PHP backdoor deployed the same way, so the attacker keeps access even if the JOMANGY web shell is found and removed.

3.3 Step-by-step: what the dropper does on execution

- 1. Environment check — the sample carries a detect-debug-environment signature, i.e. it checks for signs of a sandbox or analysis tooling before doing anything destructive, a common technique to waste analysts' time or avoid tripping automated detonation.
- 2. Fetch the next stage — it runs curl against a hard-coded attacker IP (in this sample, <http://160.119.69.4/x>) to pull down the next component; this is the single line of behavior VirusTotal's own automated analysis flagged.
- 3. Evict the competition — it searches for and removes ~50 known rival web-shell families already on the box (b374k, b3d0r, yokyok, watchTower proof-of-concept files, and even the actor's own earlier-campaign artifacts), so the newly compromised host is exclusively theirs.
- 4. Create backdoor accounts — it adds up to 18 hidden accounts across three tiers: 9 root-equivalent (UID-0) OS accounts, 8 lower-privileged service-style OS accounts, and 1 FreePBX web-panel admin account inserted directly into the application's MySQL ampusers table. All are named to look like normal FreePBX/Asterisk service accounts (asterisk, freepbxuser, sangoma, support) so they blend into a routine account listing.
- 5. Install six independent persistence mechanisms (detailed in 3.4) — the actual innovation of this family: no single fix removes the infection.
- 6. Weaken host defenses — it flips PermitRootLogin to yes in the SSH config and opens inbound TCP/22 in the firewall, in case the attacker needs a plain SSH fallback later.
- 7. Cover its tracks — it runs targeted sed -i deletions against log files to strip out lines referencing its own activity (a technique reused from the actor's prior campaigns going back to 2021).

3.4 The six persistence layers, explained

- Cron polling — a scheduled job silently re-contacts the attacker's server every 1–3 minutes and re-downloads/re-runs the payload, so even a fully wiped infection returns within minutes if the cron entry survives.
- Shell-profile injection — the dropper appends itself to files that run automatically on login or boot (/root/.bash_profile, /root/.bashrc, /etc/rc.local), so simply rebooting the server re-triggers the infection.
- Immutable crontab backups — eight copies of the malicious crontab are stashed in hidden locations and flagged immutable with chattr +i, a Linux file attribute that blocks deletion or modification even by the root user until the attribute is removed first; two independent restore loops watch and re-create these copies if one goes missing.
- Process watchdog — a lightweight monitor process checks whether the malware's beacon is still running and instantly relaunches it if a defender kills the process.

- Distributed, immutable web-shell copies — more than a dozen copies of the PHP web shells are scattered across FreePBX web-application folders, each also protected with `chattr +i`; if a defender finds and deletes one, any surviving copy can rebuild the entire stack with a single web request.
- High-Availability module executor — a PHP payload is embedded inside FreePBX's own High-Availability (failover) feature, giving the attacker a privileged execution path that doesn't depend on any of the other five layers at all.

The practical effect: removing one, two, or even five of these six layers does not remove the infection — the surviving layer(s) simply rebuild the rest, typically within minutes. This is why the response plan in Section 6 calls for a full host rebuild rather than in-place cleanup.

3.5 How it makes money — the end goal

Once the web shells are in place, the attacker's monetization command is straightforward: `asterisk -rx "channel originate Local/<num>@<context>"` instructs the Asterisk PBX engine itself to place an outbound call, routed through the victim organization's own paid SIP trunk, to a number the attacker controls or profits from. Because this is issued through Asterisk's own legitimate command interface rather than a separate dialer, it is difficult to distinguish from normal PBX administration activity without specifically watching for it. The victim's telephony carrier bills the organization for the resulting call volume — this is “toll fraud,” and it is the documented purpose of the entire chain described above.

3.6 Why it evades detection

- Obfuscation — dropped PHP payloads are encoded with a double layer (Base64 wrapped in ROT13), which defeats simple string-matching antivirus signatures without needing custom packing tools.
- Low initial detection — public reporting notes the Stage 1 dropper was originally flagged by only 4 of 76 VirusTotal engines, and the Stage 2/3 PHP web shells showed zero detections at initial submission — this sample's 22/60 score reflects detections added after the family became publicly documented, not that the technique is easy to catch on first contact.
- Blending in — backdoor account names and file paths are deliberately chosen to resemble legitimate FreePBX/Asterisk components, so a defender skimming an account or file list is less likely to notice anything wrong.

4. Simulated Attack Narrative

4.1 Initial Access — Phishing (T1566)

A Reception-department user receives a phishing email crafted with the same Social-Engineering Toolkit (SET) technique used for this project's phishing-template deliverable — e.g., a spoofed “IT Support – VoIP system maintenance” notice asking them to log into a fake portal or open an attachment. The user's HVMC-CL01-equivalent workstation is compromised, or their credentials (potentially reused for the PBX admin portal, a common real-world habit) are harvested.

4.2 Exploitation & Foothold — JOMANGY Dropper (T1190, T1059.004)

Using the harvested access, the attacker reaches the hypothetical HVMC-PBX01 FreePBX admin interface and exploits it the same way the real campaign does — CVE-2025-64328 (post-auth command injection in the filestore module) or CVE-2025-57819 (pre-auth SQL injection via the Endpoint module's `cron_jobs` table) — to execute a Bash dropper matching this project's analyzed sample family (`trojan.bash/jomangy`).

4.3 Persistence & Privilege Escalation (T1053.005, T1547.004, T1098)

The dropper installs JOMANGY's documented six-layer persistence (cron C2 polling every 1–3 minutes, shell-profile injection, immutable crontab backups, a process watchdog, immutable web-shell copies, and a self-reinstalling PHP executor) and creates backdoor OS accounts on HVMC-PBX01 named to mimic legitimate services (asterisk, freepbxuser, sangoma, admin).

4.4 Lateral-Movement Risk (T1021 / discovery toward HVMC-DC01)

Because IAMLab-Net has no segmentation, HVMC-PBX01 can reach HVMC-DC01 directly. If the attacker reuses the Reception user's harvested credentials, or if any local PBX service account shares a password with a domain account (another common real-world habit this scenario is designed to surface), the attacker gains a path toward Kerberos/LDAP on the domain controller — turning a PBX compromise into a domain-identity risk. This is a risk to test for, not an assumed certainty.

4.5 Impact — Toll Fraud (T1496) and Beyond

The primary monetized impact mirrors the real campaign: asterisk -rx "channel originate Local/<num>@<context>" commands route fraudulent, billable calls through HVMC's SIP trunks. Secondary impact, specific to this scenario, is the risk to domain-identity integrity and the loss of forensic log trail (JOMANGY's documented sed -i log scrubbing) in a healthcare environment where audit trails matter.

5. Detection Plan — Mapped to HVMC's Existing Tools

Every row below uses a tool or log source already established in this project's Network Security build — no new tooling is required to run this detection plan.

Tool / Source	Type	What to look for
Suricata (HVMC-KALI, IAMLab-Net)	IDS/IPS	Custom rule alerting on repeated outbound HTTP to the same external host at a ~1–3 min interval from HVMC-PBX01 — the JOMANGY C2-polling cadence.
Samba audit log (HVMC-DC01)	log.samba / auditd	Search for authentication or account-management events tied to any credential that was ever entered on the PBX admin portal; watch for account creation outside samba-tool provisioning windows.
Wireshark (HVMC-KALI)	Packet capture	Filter http.request on a span/capture of HVMC-PBX01 traffic; recurring small GET requests to one IP is the beacon signature.
OpenVAS / Nessus Essentials	Vulnerability scan	Flags unpatched FreePBX/Asterisk (CVE-2025-64328, CVE-2025-57819) and the post-compromise SSH misconfiguration (PermitRootLogin yes).
Host review (on HVMC-PBX01)	Manual triage	lsattr -R /var/www/html grep i (immutable files); crontab -l for unrecognized entries; diff /etc/passwd against the host's baseline; query the FreePBX ampusers MySQL table for unauthorized admin rows.
samba-tool user list (HVMC-DC01)	AD baseline diff	Compare against the Week 3 provisioned 30-user baseline for any account added outside the documented provisioning process.

6. Incident Response Plan

Follows the same Detect → Contain → Eradicate → Recover → Lessons Learned lifecycle used for the Week 3 brute-force incident-response deliverable, applied to this scenario.

Phase	Actions — mapped to HVMC's actual lab tooling
DETECT	Suricata alert on IAMLab-Net for repeated, regular-interval outbound HTTP connections from HVMC-PBX01 (consistent with a 1–3 minute C2 polling cron) → correlated with Samba audit-log review on HVMC-DC01 for any unexpected authentication or account-management events touching domain credentials that were ever used on the PBX admin panel → Wireshark capture on HVMC-KALI (filter: http.request) confirms recurring GET requests to an unrecognized external IP. Priority: HIGH — targets a system with domain-credential exposure risk, sustained/automated beaconing, healthcare environment.
CONTAIN	Isolate HVMC-PBX01 from IAMLab-Net immediately (detach its UTM vNIC or move it to an isolated host-only network) rather than powering it off — persistence mechanisms may attempt to wipe evidence on shutdown. Add a deny rule (ufw / iptables) at the gateway and on HVMC-DC01 blocking the observed C2 IP range. Force a password reset for the Reception account believed to be the phishing victim, and for any account that logged into the PBX admin panel. Do not yet trust any account list on the PBX host as authoritative — assume backdoor accounts exist until proven otherwise.
ERADICATE	Do NOT attempt in-place cleanup — JOMANGY's six-layer self-healing persistence means deleting one web shell or cron job leaves the infection able to fully rebuild within minutes. Restore HVMC-PBX01 from the last known-clean UTM snapshot taken before the incident window (or rebuild from a fresh ISO if no verified-clean snapshot exists). Before reconnecting: patch to a FreePBX/Asterisk version beyond CVE-2025-64328 and CVE-2025-57819, and run samba-tool user list on HVMC-DC01 to diff against the Week 3 baseline user list (30 users) for any account that was not part of the original provisioning.

Phase	Actions — mapped to HVMC's actual lab tooling
RECOVER	Reconnect HVMC-PBX01 on an isolated segment first (see Lessons Learned), confirm no outbound beaconing resumes via a fresh Wireshark capture, then re-enable department phone lines in stages. Re-verify SSH hardening (PermitRootLogin no) and firewall rules were not silently reopened. Monitor Suricata alerts and Samba audit logs closely for 72 hours post-recovery before declaring the incident closed.
LESSONS LEARNED	IAMLab-Net's single flat segment (no VLAN/firewall boundary between PBX, clients, and the domain controller) is the root cause that turns a PBX compromise into a domain-wide risk — recommend segmenting any future VoIP/PBX host onto its own subnet with an explicit firewall boundary to HVMC-DC01. Maintain dated, verified-clean UTM snapshots for fast, trustworthy rebuilds. Extend Suricata coverage with a beacon-interval signature. Feed this scenario back into phishing-awareness training for Reception staff, since the assumed entry vector was social engineering, not a direct exploit.

7. Alert Prioritization

Priority	Criteria (extends the Week 3 Monitor/Respond rubric answer)
HIGH	Beaconing or persistence indicators on a system with any path to HVMC-DC01 (PBX, domain-joined client); any new UID-0 / domain-admin-equivalent account not in the Week 3 baseline; Suricata alert combined with a matching Samba audit-log anomaly.
MEDIUM	A single-source anomaly confined to one non-domain-critical host (e.g., one unrecognized outbound connection from HVMC-PBX01 with no corroborating DC01 log activity).
LOW	Informational probe or scan with no successful connection, no persistence artifact, and no correlated account activity.

8. Indicator-of-Compromise Watchlist

Condensed from the JOMANGY malware diagnosis report already produced for this project; kept here as a standalone quick-reference for tabletop/response use.

Indicator	Value
SHA-256 (dropper)	679515b3d6642a102f3c8bb69c0884912bc700d2a575e2595752e8b446e39c00
C2 (this sample)	160.119.69.4 (payload path /x)
C2 (documented campaign)	45.95.147.178 (AS49870, Alsycon B.V., NL); prior C2 45.234.176.202
Related scanner IP	160.119.76.250
Watermark string	trace_e1ebf9066a951be519a24140711839ea
Suspicious account names to check	newfpbxs, newfpbx, xhimax, admin, support, sangoma, asterisk, freepbxuser, spamfilter (mimic legitimate service-account naming)
Suspicious file paths (PBX host)	/var/www/html/admin/views/ajax.php, /var/www/html/digium_phones/ajax.php, /var/www/html/admin/modules/freepbx_ha/license.php

9. Lessons Learned & Recommended Hardening

- Segment any future VoIP/PBX host onto its own subnet with an explicit firewall boundary to HVMC-DC01 — the current flat single-segment design is the single biggest amplifier of this scenario's impact.
- Maintain dated, verified-clean UTM snapshots for every lab host so eradication can mean “restore from clean baseline” rather than an untrustworthy in-place cleanup.
- Extend Suricata coverage with a beacon-interval signature (regular short-period outbound connections), which generic port/volume-based rules like the existing sid 1000010 would not catch.
- Treat any credential that touches a third-party admin portal (like a PBX) as higher-risk than a pure domain credential, and avoid password reuse between service accounts and domain accounts — reinforces this project's existing RBAC/least-privilege access-control work.
- Feed this scenario into the phishing-awareness angle of the SET deliverable: the assumed entry vector here is social engineering, not a direct exploit, which is the more realistic risk for a 30-user medical center environment.
- Patch-manage any internet- or partner-facing application (FreePBX/Asterisk in this scenario) against newly disclosed CVEs on a defined cadence — real-world tracking shows hundreds of compromised hosts remained infected many months after the entry-point CVEs were publicly patched.

10. How This Fits the 12-Week Project

This tabletop exercise deliberately reuses artifacts already produced for the project rather than inventing a new toolchain: the malware family and IOCs come from the Criterion 1 malware-analysis report; the assumed initial-access vector (phishing) is the same technique behind the Criterion 1 SET phishing-template deliverable; and the response lifecycle and alert-prioritization structure match the Network Security “Monitor and Respond to Network Security Events” rubric answer already delivered for Week 3. It can be submitted as a standalone incident-response artifact, or referenced as supporting evidence for either rubric.

Prepared for: Sabitha — Healthcare IAM Operations Home Lab | Tabletop exercise — hypothetical scenario, not a record of an actual incident.